ARION OPS

Relatório de Segurança da Aplicação

NOC ATACADO

Versão 1.3.0

02 de novembro de 2026

Concepção e desenvolvimento:
Pedro Cavalcanti

ARION Serviços de Telecomunicações

Declaração técnica da avaliação: Segurança validada no escopo e na versão avaliados.

Produto: ARION OPS

Área: NOC ATACADO

Versão avaliada: `1.3.0` (`docs/08-releases/releases.json` / `arion_geo/config/releases.py`)

Data da auditoria: 02/11/2026

Commit base auditado: `8cf5fb883bf946bf78b40cc0dcf71a92421e1652` (`feature/central-relatorios`)

Concepção e desenvolvimento: Pedro Cavalcanti

Empresa: ARION Serviços de Telecomunicações

Declaração institucional: Segurança validada no escopo e na versão avaliados.

1. Sumário Executivo

A versão `1.3.0` do **ARION OPS** foi submetida a uma auditoria defensiva controlada combinando revisão white-box completa do código-fonte, testes ativos não destrutivos em ambiente local (`127.0.0.1` / Django `5.2.18` + MySQL `8.4.7` + Waitress `3.0.2`) e validação passiva da superfície pública de produção (`https://nocatacadoarion.bicoai.com.br` via Cloudflare Tunnel).

No escopo testado, **não foram identificadas vulnerabilidades críticas ou de alta severidade**, e **todos os 6 achados de código/configuração (3 médios e 3 baixos) foram corrigidos e retestados nesta rodada**, restando `0` vulnerabilidades abertas no código da aplicação.

Resultados por Severidade

Severidade	Encontrados	Corrigidos	Mitigados / Aceitos	Abertos no Código
Crítico	0	0	0	0
Alto	0	0	0	0
Médio	3	3	0	0
Baixo	4	3	1	0
Informativo	1	0	1	0
Total	**8**	**6**	**2**	**0**

Nota sobre borda externa (`SEC-003`): A configuração de redirecionamento HTTPS (`SECURE_SSL_REDIRECT=True`), reconhecimento seguro de proxy (`SECURE_PROXY_SSL_HEADER` + `--trusted-proxy=127.0.0.1` no Waitress) e emissão de HSTS (`SECURE_HSTS_SECONDS=31536000`) foi corrigida e validada no código do ARION OPS. Como esta auditoria não executa deploy nem acessa o painel externo da conta Cloudflare, a ativação complementar de *Always Use HTTPS* e *HSTS* no painel Cloudflare está registrada como **AÇÃO DE INFRAESTRUTURA PENDENTE** (Seção 12).

Conclusão Executiva

A versão avaliada do ARION OPS foi submetida a revisão white-box, testes ativos controlados em ambiente local e validação passiva da superfície pública. No escopo testado, não foram identificadas vulnerabilidades críticas ou de alta severidade pendentes após as correções realizadas. Os principais controles de autenticação, rate limiting de login, sessão, CSRF, RBAC, Data Scope, consultas ao banco, exportações, uploads e integrações foram validados. Os riscos residuais remanescentes são classificados e documentados como hardening ou dependências de infraestrutura.

2. Escopo e Metodologia

2.1 Distinção entre Desenvolvimento Local e Produção Pública

- **Desenvolvimento local (`ARION_ENV=development`):**

- Opera sobre `http://127.0.0.1:8000` (ou `localhost`).
- O uso de HTTP em loopback local é esperado e permitido para desenvolvimento, não constituindo vulnerabilidade.
- **Produção pública (`ARION_ENV=production`):**
- Fluxo arquitetural: `Internet -> HTTPS -> Cloudflare -> Cloudflare Tunnel (cloudflared) -> 127.0.0.1:8100 (Waitress) -> Django`.
- O trecho `cloudflared -> Waitress` ocorre exclusivamente em loopback (`127.0.0.1:8100`), enquanto o acesso externo do usuário exige obrigatoriamente **HTTPS**.

2.2 Metodologia Aplicada

- 1. **Mapeamento de superfície de ataque:** Inventário completo de rotas públicas, autenticadas, APIs JSON, exportações CSV/XLSX/PDF, uploads do ARI e rotas administrativas em `arion_geo/config/urls.py` e sub-módulos.
- 2. **Análise White-Box estática:** Varredura automatizada em todo o código Python, templates HTML e JavaScript (`frontend_src/js/`) em busca de `csrf_exempt`, `mark_safe`, `format_html`, `|safe`, `RawSQL`, `.extra()`, `.raw()`, `cursor.execute`, `innerHTML`, `eval`, `exec`, `subprocess`, `pickle` e armazenamento em `localStorage`/`sessionStorage`.
- 3. **Testes Ativos Controlados (Local):** Testes com 5 perfis de acesso (`Anônimo`, `Autenticado sem permissão`, `Operacional RO`, `Gestor`, `Administrador`), validação de interseção do `DataScopeService`, tentativas de IDOR, Mass Assignment, CSRF, Open Redirect, rotação/invalidação de sessão, rate limiting de login, SQL Injection, XSS refletido, Formula Injection, injeção de tags em PDF e upload de arquivos maliciosos.
- 4. **Verificação Passiva de Produção:** Inspeção não destrutiva de status HTTP, cabeçalhos de segurança e atributos de cookies em `nocatacadoarion.bicoai.com.br`.

3. Inventário da Superfície de Ataque e Matriz RBAC

3.1 Rotas Mapeadas

Módulo / Rota	Tipo	Controle de Acesso	Escopo de Dados
`/login/`, `/logout/`	Autenticação	Público (`GET /login/`), `POST` com CSRF e Rate Limit	N/A
`/health/`, `/api/version/`, `/manifest.webmanifest`, `/service-worker.js`	Infra / PWA	Público somente leitura (`GET`)	Sem dados operacionais
`/painel/`, `/dashboard/`, `/cockpit/`	Operacional	`@login_required` + `view_dashboard` / `view_cockpit`	`DataScopeService`
`/chamados/`	Operacional	`@login_required` + `view_tickets`	`DataScopeService`
`/mapa/`	Operacional	`@login_required` + `view_map`	`DataScopeService`
`/rankings/`, `/rankings/exportar/xlsx/`, `/rankings/exportar/pdf/`	Operacional / Export	`@login_required` + `view_rankings`	`DataScopeService`
`/qualidade/`, `/qualidade/links-prioritarios/<ci>/`	Operacional	`@login_required` + `view_quality`	`DataScopeService`
`/base/`, `/base/api/links/`, `/base/api/mapa/`, `/base/exportar-csv/`	Operacional / API / Export	`@login_required` + `view_links`	`DataScopeService`

Módulo / Rota	Tipo	Controle de Acesso	Escopo de Dados
`/ari/`, `/ari/api/conversas/...`	Assistente IA / Upload	`@login_required` + `view_ari` + titularidade (`user=request.user`)	Isolado por usuário + `DataScopeService`
`/relatorios/`	Gestão / Relatórios	`@login_required` + `view_reports`	`DataScopeService`
`/configuracoes/`, `/configuracoes/seguranca/`, `/configuracoes/aparencia/`	Conta	`@login_required` (próprio usuário)	Próprio usuário
`/configuracoes/documentacao/`, `/configuracoes/sobre/`	Institucional	`@login_required`	Global institucional
`/configuracoes/administracao/usuarios/...`	Administração	`@login_required` + `manage_users`	Global administrativo
`/configuracoes/administracao/grupos/...`	Administração	`@login_required` + `manage_groups`	Global administrativo
`/configuracoes/administracao/escopos/...`	Administração	`@login_required` + `manage_data_scopes`	Global administrativo
`/configuracoes/administracao/auditoria/`	Administração	`@login_required` + `view_audit`	Global administrativo
`/configuracoes/administracao/integracoes/...`	Administração	`@login_required` + `view_integrations` / `manage_integrations`	Global administrativo
`/configuracoes/administracao/sistema/`	Administração	`@login_required` + `view_system`	Global administrativo

3.2 Matriz Real de Permissões Verificada

Recurso	Anônimo	Autenticado s/ Permissão	Analista NOC (RO)	Gestor	Administrador
Dashboard (`/dashboard/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Chamados (`/chamados/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Cockpit (`/cockpit/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Mapa (`/mapa/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Rankings (`/rankings/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Qualidade (`/qualidade/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Base (`/base/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
ARI (`/ari/`)	`302 -> /login/`	`403 Forbidden`	`200 OK`	`200 OK`	`200 OK`
Minha Conta (`/configuracoes/`)	`302 -> /login/`	`200 OK`	`200 OK`	`200 OK`	`200 OK`
Documentação (`/configuracoes/documentacao/`)	`302 -> /login/`	`200 OK`	`200 OK`	`200 OK`	`200 OK`

Recurso	Anônimo	Autenticado s/ Permissão	Analista NOC (RO)	Gestor	Administrador
Usuários (`/configuracoes/administracao/usuarios/`**)**	`302 -> /login/`	`403 Forbidden`	`403 Forbidden`	`403 Forbidden`	`200 OK`
Grupos (`/configuracoes/administracao/grupos/`**)**	`302 -> /login/`	`403 Forbidden`	`403 Forbidden`	`403 Forbidden`	`200 OK`
Escopos (`/configuracoes/administracao/escopos/`**)**	`302 -> /login/`	`403 Forbidden`	`403 Forbidden`	`403 Forbidden`	`200 OK`
Auditoria (`/configuracoes/administracao/auditoria/`**)**	`302 -> /login/`	`403 Forbidden`	`403 Forbidden`	`403 Forbidden`	`200 OK`
Integrações (`/configuracoes/administracao/integracoes/`**)**	`302 -> /login/`	`403 Forbidden`	`403 Forbidden`	`403 Forbidden`	`200 OK`
Sistema (`/configuracoes/administracao/sistema/`**)**	`302 -> /login/`	`403 Forbidden`	`403 Forbidden`	`403 Forbidden`	`200 OK`

4. Detalhamento dos Achados, Correções e Retestes

SEC-001 — Formula Injection em Exportações de Planilha (CSV / XLSX)

- **Severidade:** MÉDIO
- **Componente:** `arion_geo/aplicativos/base_links/views.py` (`exportar_csv_links`) e `arion_geo/aplicativos/painel/views.py` (`_safe_spreadsheet_text`)
- **Descrição:** A exportação CSV da Base escrevia valores textuais diretamente no CSV sem neutralizar prefixos interpretados como fórmulas por softwares de planilha (`=`, `+`, `-`, `@`), e a função `_safe_spreadsheet_text` do Cockpit não aplicava `.lstrip()` antes de checar o primeiro caractere (permitindo bypass com espaços ou tabulações iniciais como `\t=SUM(1+1)`).
- **Impacto:** Caso um registro sincronizado contivesse texto iniciado por `=`, `+`, `-` ou `@`, a abertura do arquivo exportado no Microsoft Excel ou LibreOffice Calc poderia acionar avaliação de fórmulas locais.
- **Correção aplicada:** Implementada a função `_safe_csv_value` em `arion_geo/aplicativos/base_links/views.py` e atualizado `_safe_spreadsheet_text` em `arion_geo/aplicativos/painel/views.py` usando `text.lstrip().startswith(("=", "+", "-", "@"))` para prefixar `'`.
- **Reteste:** Validado com os payloads `=SUM(1+1)`, `+SUM(1+1)`, `-SUM(1+1)`, `@SUM(1+1)` e `\t=SUM(1+1)` em `SpreadsheetExportSafetyTests` e `SecurityRegressionBaselineTests` — todos saíram neutralizados com apóstrofo inicial.
- **Status: CORRIGIDO**

SEC-002 — Aceitação de URL HTTP na Configuração e Cliente da CMDB

- **Severidade:** MÉDIO
- **Componente:** `arion_geo/aplicativos/integracoes/forms.py` (`CMDBConfigurationForm.clean_base_url`) e `arion_geo/aplicativos/integracoes/clients/cmdb.py` (`CMDBClient.__init__`)

- **Descrição:** O validador de URL da CMDB aceitava esquemas `http://` além de `https://`, apesar de a integração transmitir `UserLogin` e `Password` no payload JSON das requisições.
- **Impacto:** Uma configuração acidental com `http://` exporia credenciais de integração em trânsito caso o tráfego saísse do host.
- **Correção aplicada:** Restringidos `CMDBConfigurationForm.clean_base_url` e `CMDBClient.__init__` para aceitar exclusivamente `parsed.scheme.casefold() == "https"` com hostname válido.
- **Reteste:** Validado em `test_cmdb_client_and_form_reject_non_https_urls` (`http://example.com` rejeitado; `https://example.com` aceito estruturalmente sem conectar a host real).
- **Status: CORRIGIDO**

SEC-003 — Redirecionamento HTTP -> HTTPS, Proxy Header do Waitress e HSTS em Produção

- **Severidade:** MÉDIO
- **Componente:** `arion_geo/config/settings.py`, `deploy/windows/run_process.py` e borda Cloudflare (`nocatacadoarion.bicoai.com.br`)
- **Descrição:** Na verificação passiva externa, `http://nocatacadoarion.bicoai.com.br/login/` respondeu `HTTP 200 OK` sem redirecionar para `https://` e `https://nocatacadoarion.bicoai.com.br/login/` não apresentou o cabeçalho `Strict-Transport-Security`. A análise white-box revelou a causa raiz no servidor local: o Waitress 3.0.2 possui `clear_untrusted_proxy_headers=True` por padrão e removia `X-Forwarded-Proto` enviado pelo `cloudflared` em `127.0.0.1` porque `--trusted-proxy=127.0.0.1` não estava configurado em `deploy/windows/run_process.py`, o que levou anteriormente a desativar `SECURE_SSL_REDIRECT` em `settings.py` e impedia o `SecurityMiddleware` de emitir HSTS.
- **Impacto:** Usuários que digitassem explicitamente `http://` poderiam realizar a primeira requisição em texto claro até a borda Cloudflare se o redirecionamento automático não estivesse ativo na borda ou na aplicação.
- **Correção aplicada no ARION OPS:**
- 1. Em `deploy/windows/run_process.py`, configurado o Waitress com `--trusted-proxy=127.0.0.1`, `--trusted-proxy-count=1`, `--trusted-proxy-headers=x-forwarded-for x-forwarded-proto x-forwarded-host` e `--clear-untrusted-proxy-headers` (seguro porque o Waitress escuta exclusivamente em `127.0.0.1`);
- 2. Em `arion_geo/config/settings.py` (`ARION_ENV=production`), mantido `SECURE_PROXY_SSL_HEADER = ("HTTP_X_FORWARDED_PROTO", "https")`, ativado `SECURE_SSL_REDIRECT = env_bool("DJANGO_SECURE_SSL_REDIRECT", True)` e configurado `SECURE_HSTS_SECONDS = int(os.getenv("DJANGO_SECURE_HSTS_SECONDS", "31536000"))` (com `SECURE_HSTS_INCLUDE_SUBDOMAINS = False` e `SECURE_HSTS_PRELOAD = False`).
- **Reteste:** Validado localmente em `test_cloudflare_https_forwarded_proto_avoids_redirect_loop_and_emits_gradual_hsts`: requisições simulando o túnel com `HTTP_X_FORWARDED_PROTO="https"` retornam `200 OK` com `Strict-Transport-Security: max-age=31536000` (sem loop), e requisições com `HTTP_X_FORWARDED_PROTO="http"` retornam `301 Moved Permanently` para `https://`.
- **Status: CORRIGIDO NO REPOSITÓRIO / AÇÃO DE INFRAESTRUTURA PENDENTE NO PAINEL CLOUDFLARE** (ver instruções exatas na Seção 12).

SEC-004 — Proteção contra Tentativas Repetidas de Login (Rate Limiting Local)

- **Severidade:** BAIXO
- **Componente:** `arion_geo/aplicativos/autenticacao/throttle.py`, `arion_geo/aplicativos/autenticacao/forms.py` e `arion_geo/config/settings.py`
- **Descrição:** O endpoint `POST /login/` não possuía limitador local de tentativas consecutivas de autenticação.
- **Impacto:** Possibilidade de tentativas automatizadas de adivinhação de senha caso a proteção da borda não bloqueasse a origem.

- **Correção aplicada:** Criado o módulo `arion_geo/aplicativos/autenticacao/throttle.py` utilizando o cache nativo do Django (`django.core.cache.cache`), aplicando bloqueio temporário por `900` segundos (15 minutos) após `5` falhas para o mesmo par `(IP normalizado, usuário normalizado)` ou `20` falhas para o mesmo `IP`. Durante o bloqueio, `LoginForm.clean()` interrompe a execução antes de `authenticate()` e retorna exatamente a mesma mensagem genérica de credenciais inválidas. O login válido limpa imediatamente os contadores (`clear_login_failures`).
- **Reteste:** Validado em `test_login_rate_limiting_blocks_after_threshold_and_keeps_generic_message`, `test_successful_login_clears_failure_counter` e em teste ativo no endpoint `/login/` (5 falhas -> 6ª tentativa bloqueada mesmo com senha correta e mensagem idêntica -> expiração/reset do cache -> login válido `302 -> /painel/`).
- **Status: CORRIGIDO**

SEC-005 — Proteção Preventiva Fail-Closed de TLS para Conexão Remota do OTRS

- **Severidade:** BAIXO
- **Componente:** `arion_geo/aplicativos/integracoes/clients/otrs.py`, `arion_geo/aplicativos/integracoes/forms.py` e `arion_geo/aplicativos/integracoes/services/errors.py`
- **Descrição:** O `OTRSReadOnlyClient` (atualmente com integração `enabled=False`) não exigia explicitamente parâmetros TLS (`ssl`) no `pymysql.connect` quando configurado com um host remoto.
- **Impacto:** Caso a integração fosse ativada futuramente apontando para um IP externo sem túnel/VPN, o tráfego MySQL poderia ocorrer sem criptografia TLS.
- **Correção aplicada:** Implementada política *fail-closed* em `OTRSReadOnlyClient` e `OTRSConfigurationForm`:
- Para hosts de loopback (`127.0.0.1`, `localhost`, `::1`), o comportamento local sem TLS permanece permitido;
- Para qualquer host remoto, `use_tls` é `True` por padrão e obrigatório: se `use_tls=False` ou `ssl_verify=False`, o formulário rejeita a configuração e `_build_ssl_context()` lança `OTRSTLSRequiredError` antes de abrir conexão; quando ativo, exige TLS 1.2+ e `ssl.CERT_REQUIRED` (`ARION_OTRS_SSL_CA` / `ssl_ca`). A integração permaneceu `enabled=False` e nenhuma conexão ao OTRS real foi realizada.
- **Reteste:** Validado em `test_remote_host_requires_tls_fail_closed_while_loopback_allows_local_mode` e `test_otrs_remote_host_requires_tls_fail_closed`.
- **Status: CORRIGIDO**

SEC-006 — Superfície de Escuta do Serviço MySQL Local (`bind_address`)

- **Severidade:** BAIXO
- **Componente:** Serviço Windows MySQL `8.4.7` local (`C:\ProgramData\MySQL\MySQL Server 8.0\my.ini`)
- **Descrição:** O serviço MySQL local possui `@@bind_address = '*'` (escutando em `::` nas portas `3306` e `33060`).
- **Mitigação existente confirmada:**
- 1. A conta da aplicação existe apenas como `'arion'@'localhost'` (conexões externas não autenticam);
- 2. Os privilégios de `'arion'@'localhost'` são restritos exclusivamente ao schema `arion_ops.*` (sem `SUPER`, `FILE` ou `GRANT OPTION`);
- 3. O Windows Firewall está habilitado nos perfis `Domain`, `Private` e `Public` com bloqueio de entrada por padrão.
- **Ação realizada:** Criado o script seguro e somente leitura `deploy/windows/hardening-mysql.ps1`, que diagnostica portas, firewall e localização do `my.ini` e orienta a adição de `bind-address=127.0.0.1` e `mysqlx-bind-address=127.0.0.1` sob `[mysqld]` em janela de manutenção.
- **Status: MITIGADO**

SEC-007 — Alinhamento entre `production_check.py` e `config/settings.py`

- **Severidade:** BAIXO
- **Componente:** `deploy/windows/production_check.py` e `arion_geo/config/settings.py`

- **Descrição:** Havia divergência entre `deploy/windows/production_check.py` (que exigia `SECURE_SSL_REDIRECT is True`) e `arion_geo/config/settings.py` (que definia `SECURE_SSL_REDIRECT = False`).
- **Correção aplicada:** Com a configuração de `--trusted-proxy=127.0.0.1` no Waitress (`deploy/windows/run_process.py`) e `SECURE_SSL_REDIRECT = True` + `SECURE_HSTS_SECONDS = 31536000` em `arion_geo/config/settings.py`, `deploy/windows/production_check.py` foi atualizado para validar explicitamente `SECURE_PROXY_SSL_HEADER`, `SECURE_SSL_REDIRECT`, `SECURE_HSTS_SECONDS >= 3600` e as demais garantias de produção.
- **Reteste:** Validado executando `deploy/windows/production_check.py` em modo de produção — todas as verificações de segurança e `Django check --deploy` passaram sem erros.
- **Status: CORRIGIDO**

SEC-008 — Política Global de CSP em Modo `Report-Only` na V1

- **Severidade:** INFORMATIVO
- **Componente:** `arion_geo/config/settings.py` e `arion_geo/config/middleware.py` (`ProductionSecurityHeadersMiddleware`)
- **Descrição:** O cabeçalho global de CSP é enviado como `Content-Security-Policy-Report-Only` nas páginas HTML da aplicação (enquanto os artefatos HTML do ARI utilizam `Content-Security-Policy: sandbox` em modo de bloqueio ativo).
- **Avaliação técnica:** Mantido em `Report-Only` para o shell global na V1 a fim de evitar regressões visuais em tiles/workers do Mapbox GL JS, gráficos ECharts e carregamento PWA, sendo registrado de forma transparente como hardening evolutivo planejado e não bloqueador da V1 (o modo `Report-Only` não bloqueia execução por si só; a proteção contra XSS repousa no auto-escape dos templates Django, sanitização em `render_markdown` e helpers de escape no JavaScript).
- **Status: ACEITO (Hardening planejado, não bloqueador da V1)**

5. Resultados Detalhados dos Testes de Segurança

5.1 Autenticação, Sessão, CSRF e Rate Limiting

- **Credenciais válidas e inválidas:** Testadas em `/login/`. Falhas retornam `HTTP 200` com mensagem genérica idêntica para usuário existente, usuário inexistente, conta inativa ou tentativa bloqueada pelo rate limit.
- **Rate Limiting (`SEC-004`):** Após `5` falhas consecutivas para o mesmo usuário/IP, a 6ª tentativa é bloqueada mesmo informando a senha correta, sem acionar `authenticate()`. Após expiração/limpeza do cache, o login válido sucede (`302 -> /painel/`) e zera o contador.
- **Rotação de Sessão (Anti-Session Fixation):** Confirmado que `session.session_key` muda após o login (`session_rotated_on_login = True`).
- **Logout e Replay de Sessão:** Após `POST /logout/`, a reutilização do cookie anterior em `/painel/` retorna `302 -> /login/?next=/painel/`.
- **CSRF:** 0 ocorrências de `csrf_exempt` no código. Requisições `POST` sem token ou com token inválido em `/login/`, `/logout/`, `/configuracoes/` e `/ari/api/conversas/nova/` retornaram `403 Forbidden`.

5.2 Autorização (RBAC), Data Scope, IDOR e Mass Assignment

- **Isolamento de Data Scope (`GroupDataScope.Mode.CUSTOM`):** Testado com grupo restrito à interseção `Operadora = VIVO` e `Projeto = Arcos Dourados`:
- `/base/api/links/`: retornou exatamente **199 links** para o usuário restrito, contra **3.446 links** para o Administrador.
- `/base/api/mapa/`: retornou **199 links** e **1 projeto** nos agregados do usuário restrito, contra **3.446 links** e **24 projetos** globais (sem vazamento de contagem global).
- Tentativa de bypass por query string (`?project=OutroProjeto`): bloqueada pelo backend, mantendo a interseção do escopo.

- **Proteção contra IDOR:**
- Acesso direto a link fora do escopo (`/base/api/links/1/` e `/qualidade/links-prioritarios/089019805509/`): bloqueado com `404 Not Found`.
- Acesso e tentativa de exclusão de conversa do ARI pertencente a outro usuário (`/ari/api/conversas/<id>/` e `/excluir/`): bloqueados com `404 Not Found`.
- **Proteção contra Mass Assignment:** `POST /configuracoes/` enviando `is_superuser=True&is_staff=True` manteve `is_superuser=False` e `is_staff=False`.

5.3 SQL Injection, XSS, Exportações e Uploads

- **SQL Injection:** 0 ocorrências de `.raw()`, `.extra()` ou `RawSQL`. Payloads `' OR '1'='1' --` testados em `/base/`, `/base/api/links/`, `/chamados/`, `/rankings/`, `/qualidade/` e `/painel/api/dashboard/` retornaram `200 OK` sem erro `500` e sem ampliação de resultados. O uso do Django ORM e queries parametrizadas reduz a exposição a SQL Injection nos fluxos avaliados.
- **XSS Refletido e Armazenado:** 0 ocorrências de `mark_safe` ou `format_html`. As 81 ocorrências de `innerHTML` em `frontend_src/js/` utilizam funções explícitas de escape (`esc`, `escapeHTML`, `escapeHtml`, `escapeTooltip`). O payload `<img src=x onerror=console.log('xss-test')>` foi escapado em todas as rotas testadas (`raw_xss_unescaped = False`).
- **Exportações CSV, XLSX e PDF:** Neutralização de fórmulas (`=`, `+`, `-`, `@`, `\t=`) validada em todas as exportações de planilhas; escape XML (`xml_escape`) validado na geração de PDF com ReportLab.
- **Uploads do ARI:** Arquivos `.svg`, `.html`, `.pdf` com assinatura inválida e `.pdf.exe` foram rejeitados por `validate_upload` (`ValidationError`), e o nome `..\..\relatorio.txt` foi sanitizado para `relatorio.txt`.

6. Instruções Exatas para a Borda Cloudflare (Ação de Infraestrutura Pendente)

Como o agente de auditoria não possui acesso ao painel externo da conta Cloudflare nem executa deploy/reinício de serviços de produção, recomenda-se ao administrador da infraestrutura validar no painel Cloudflare do domínio `bicoai.com.br` / `nocatacadoarion.bicoai.com.br`:

- 1. **Redirecionamento HTTP -> HTTPS na borda:**
- Acessar **Cloudflare Dashboard** → **SSL/TLS** → **Edge Certificates**;
- Habilitar **Always Use HTTPS = ON**.
- 2. **HSTS na borda (opcional / alinhado ao Django):**
- Acessar **Cloudflare Dashboard** → **SSL/TLS** → **Edge Certificates** → **HTTP Strict Transport Security (HSTS)**;
- Habilitar HSTS com **Max Age: 12 months (`31536000`)**, mantendo **Include subdomains: OFF** e **Preload: OFF** (a menos que todos os subdomínios de `bicoai.com.br` operem exclusivamente em HTTPS).
- 3. **Aplicação na janela de deploy local:**
- Na próxima janela de atualização do serviço Windows, reiniciar o processo `web` (`deploy/windows/restart-arion.ps1`) para que o Waitress passe a operar com os novos argumentos `--trusted-proxy=127.0.0.1` e a configuração `SECURE_SSL_REDIRECT=True` / `SECURE_HSTS_SECONDS=31536000`.
- 4. **Hardening opcional do MySQL local (`SEC-006`):**
- Executar `powershell -ExecutionPolicy Bypass -File .\deploy\windows\hardening-mysql.ps1` para diagnóstico e, em janela de manutenção programada, adicionar `bind-address=127.0.0.1` e `mysqlx-bind-address=127.0.0.1` no `my.ini`.